

How to Implement Least Privilege Security

Estimated time needed: 10 minutes

According to NIST, **least privilege** is the principle that a security architecture should be designed in a way that each entity (user or network resource) is granted the minimum system resources and authorizations that the entity needs to perform its function.

Source: https://csrc.nist.gov/glossary/term/least_privilege#:~:text=Definitions%3A,needs%20to%20perform%20its%20function

Objectives

After completing this lab, you will be able to:

1. Explain what it means to implement the least privilege principle
2. Select the most appropriate tool to implement least privilege in a given scenario

Implementing the Principle of Least Privilege

Implementing the Principle of Least Privilege in a network architecture involves restricting user access rights to only what is necessary for their work. This means each user will ONLY have permissions to perform their job tasks. It involves setting up stringent user access controls and regularly reviewing and updating them to remain relevant as roles and responsibilities change.

Let's look at common tools implemented to ensure the least privilege.

Tools for achieving least privilege

Various tools can be used to implement the Principle of Least Privilege.

Identity and Access Management (IAM)

Identity and Access Management (IAM) is a cybersecurity discipline that manages user identities and access permissions on a computer network. IAM tools help manage resource access, ensuring only authorized users have access. While IAM policies, processes, and technologies can differ between companies, any IAM initiative aims to ensure that the right users and devices can access the right resources for the right reasons at the right time. <https://www.ibm.com/topics/identity-access-management>

IAM works by first authenticating the identity of a user when they try to access a system or application. Once authenticated, the system will verify the user's access level based on their role in the organization (known as 'authorization'). This ensures that individuals only have access to the resources they need to perform their job functions, in line with the Principle of Least Privilege.

Example

Consider a global financial corporation, Worldwide Capital, experiencing unauthorized access to sensitive client data, leading to significant data breaches. The breaches threaten their customers' trust and expose the corporation to severe regulatory penalties and financial losses.

Worldwide Capital implemented the IAM to address these vulnerabilities. They realized that the key to reducing unauthorized access was to ensure strict authentication and authorization before providing access to sensitive data. With IAM, they could establish stringent policies that define who can access what data and the conditions under which they can do so.

Worldwide Capital saw a notable decrease in breaches post-implementation. They verified each user's identity and controlled their access based on their role in the organization. IAM allowed them to efficiently manage digital resources and ensure that the Principle of Least Privilege was followed. This helped to increase the company's data security and improved its compliance with financial regulations. It also helped to improve user management processes by providing a secure access control system that could adapt to the changing roles and responsibilities within the organization.

Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) systems grant permissions to users based on their role within the organization.

RBAC is a method of restricting system access to authorized users based on their roles within an organization. It operates because only some users need access to every resource. Instead, access rights are assigned to specific organizational functions, and users are assigned appropriate roles. As a result, users gain permissions for the tasks they perform in the context of their roles, but no more, thereby upholding the Principle of Least Privilege. RBAC enhances security, simplifies administrative work, and can improve operational efficiency.

Example

Consider a fast-growing tech startup, Velocity Tech. As the team expanded, it needed help managing user access to its internal platforms. The IT staff were continually involved with managing individual access rights, and there were incidents of employees accessing sensitive information outside their job requirements.

To mitigate these problems, Velocity Tech implemented RBAC. They categorized the employees into distinct roles: Developers, Project Managers, HR, Sales, Marketing, and IT Support. Each role was granted access rights and permissions for its specific job function. For example, Developers were given access to the code repositories and development tools, while HR staff were granted access to employee databases and payroll systems.

Implementing RBAC streamlined the process of managing and controlling user access. It eliminated the time-consuming task of assigning permissions individually, freeing up valuable time for the IT staff. More importantly, implementing RBAC reduced the risk of unauthorized access to sensitive data. As a result, Velocity Tech maintained a secure, efficient, and well-structured access control system.

Privileged Access Management (PAM)

Privileged Access Management (PAM) solutions are another tool that helps manage and audit all privileged accounts and access within a network. These tools can help an organization implement the Principle of Least Privilege when used in conjunction.

PAM is an identity security solution that helps protect organizations against cyber threats by monitoring, detecting, and preventing unauthorized privileged access to critical resources. PAM works through a combination of people, processes, and technology, giving you visibility into who uses privileged accounts and what they do while logged in. Limiting the number of users with access to administrative functions increases system security while additional layers of protection mitigate data breaches by threat actors. (<https://www.microsoft.com/en-us/security/business/security-101/what-is-privileged-access-management-pam>)

PAM solutions' high-level functioning involves controlling and monitoring access to an organization's critical systems and resources. Initially, a PAM solution identifies all privileged accounts within the network. Following this, it secures these accounts by regularly updating and randomizing their credentials, making it difficult for unauthorized users to gain access. When privileged users need to access a system, they request access through the PAM tool. The tool then verifies the user's identity and checks their access rights before granting the requested access. Any activity performed under this privileged account is logged and monitored for any signs of suspicious behavior. Through this continuous cycle of identification, securing, granting, and monitoring, PAM solutions uphold the Principle of Least Privilege, providing a robust security layer against potential internal and external threats.

Example

Imagine Optima Health, a leading healthcare provider, manages vast quantities of sensitive patient data. The healthcare provider grappled with too many privileged accounts as the network expanded to accommodate growing patient demands. These accounts, which had elevated access rights, posed significant security risks. There had been instances where privileged accounts were being exploited by attackers, leading to unauthorized access and data breaches.

Recognizing the need for enhanced security, Optima Health implemented a PAM solution. The primary objective was to secure all privileged accounts and monitor their activities to prevent unauthorized access or misuse.

Once the PAM solution was implemented, it identified all privileged accounts within the network. It secured them by routinely updating and randomizing their credentials. This ensured that even if login details were compromised, they would soon be outdated, preventing unauthorized access. Any privileged user now had to request access through the PAM tool, which would then verify their identity and access rights before granting access.

Optima Health noticed a remarkable decrease in unauthorized access and data breaches after implementation. The solution provided a continuous cycle of identification, securing, granting, and monitoring, thus establishing a robust security layer. It allowed Optima Health to maintain stringent control over its privileged accounts, significantly enhancing its security posture and reinforcing the trust of its patients.

Author

Dee Dee Collette



Skills Network